



Security Policy Case Study

Muhammad Anas Bin Naeem

Table of Contents

<i>Incident Response Management and Disaster Recovery</i>	3
<i>Security Training and Education</i>	5
<i>Conclusion</i>	6
<i>Reference:</i>	7

The Need for Information Security Management for Small to Medium Size Enterprises (SMEs)

Small to Medium Enterprises (SMEs) increasingly face significant cybersecurity threats due to their rising digital dependence. Information security management has become a crucial aspect for these SMEs, especially for those solely operating in the digital space, as they are more vulnerable to cyberattacks and data breaches. According to (Khan et al., 2020), SMEs are becoming dependent on technology, but not all of them are taking the necessary steps to ensure information security. It has been reported that 80-90% of the market share is owned by SMEs, but most of the effort in Information Security Management (ISM) is concentrated on large businesses, as they account for around 50% of the turnover. However, in the eyes of the hacker, they are seen to be very huge targets.

SMEs think that they will not be a target due to their company size and the revenue they generate compared to large organizations. 31% of cyber-attacks are targeted towards SMEs due to their weaker security measures.

(Khan et al., 2020) states ‘According to Symantec Global SMB survey conducted in 2013 it was found that 31% of the attacks taking place in the cyberspace is targeted towards SMEs due to their weaker security measures.’ According to SME statistics, 61% of Small to Medium Businesses (SMBs) experienced cyberattacks in 2017, due to which they lost billions of dollars.

When comparing SMEs to large organizations, SMEs have quite a few disadvantages when it comes to setting up and managing information security, as larger organizations can allocate the necessary financial resources to invest in industry-standard authentication solutions. In contrast, SMEs often do not have enough budget which forces them to rely on basic security measures like simple Microsoft passwords or similar protocols (Khan et al., 2020). However, this does not mean that SMEs should take it easy and not implement ISM in their businesses. This shows that Information Security Management plays a very important role in keeping the organization functioning, especially when it is particularly difficult for SMEs to cope with the losses and their reputation if they fall prey to a cyberattack.

Information Security Management enables SMEs to implement incident response planning which allows to detect when the SME is under an attack so that they can start their recovery efforts quickly. This approach helps prevent extensive or irreversible damage before it escalates beyond control. A disaster recovery plan will also assist in recovering and containing the damage done by a cyberattack, as stated (Khan et al., 2020).

Incident Response Management and Disaster Recovery

Incident response is the process of dealing with a data breach or cyberattack, including how an organization attempts to control the consequences of such an incident (BlueVoyant, n.d.). Incident response management and disaster recovery are crucial for businesses, especially for SMEs, to protect customer information and prevent financial losses, especially when SMEs do not have financial stability as compared to large organizations, so they will have a big impact if they take a hit from an attack, as stated by (Sicard, 2019).

Without having an incident response and disaster recovery management plan, SMEs can lose a lot of money resulting in high costs. According to (Sicard, 2019), ‘Over 95% of large

corporations report that one hour of continuous technology disruption can result in costs exceeding \$100,000 in a given year'. Compare this with the losses that would be incurred by SMEs, and due to their size and financial condition. They will most likely go bankrupt, as the author (Sicard, 2019) says that 4 out of 5 businesses that experience technology disruptions go out of business within a year and a half and also that 98% of businesses are not capable of recovering from their last disruption within an hour. This could be a combination of both SMEs and large organizations, but due to their company size nature, it is more likely that SMEs are more affected, especially the ones without ISM, such as incident response and disaster recovery plans.

Incident response and disaster recovery have become a necessity in today's technologically driven business world (Sicard, 2019). This is because a significant amount of consumer information is put into businesses' information systems. That is especially the case for SMEs that are solely e-commerce-driven. Consumers consent to their data being stored with the expectation that their information will be kept secure and private. For these reasons having an incident response plan and disaster recovery is essential for SMEs as if they go through an attack and are not able to keep the data confidential, they can face huge losses and even possibly legal problems that will put the business go out of business.

To create a disaster recovery plan, the company needs to consider that disasters can either be natural or man-made, such as cyberattacks. (Sicard, 2019) defines natural disasters as "extreme, sudden events caused by environmental factors" that result in catastrophic damage or the loss of life in the affected area (Fact Monster, 2017, para. 1).

Due to this, when creating a DR plan, some preliminary work needs to be done to consider both disasters and worst-case scenarios should be planned for first. (Sicard, 2019) states that in (Jefferson, 2017, para. 4), the author says a business that was affected by Hurricane Harvey in Houston, Texas, gave the statement, "Many did not take the worst-case scenario seriously until it became reality". This shows the importance that even the worst-case should always be considered even if the chances are near zero. Developing an IR and DR plan in large organizations is a massive task that requires an entire team to do months of planning, assessments, and thorough documentation.

(Sicard, 2019) states that the organization must develop formal documentation that outlines detailed plans, step-by-step processes to follow, designated roles, and backup procedures. This might differ from implementing IR and DR in SMEs as they are much smaller and do not have a dedicated team to work on this. They will also lack the financial resources needed for the planning.

(Shinde & Kulkarni, 2021) says that having no incident response plan may result in legal consequences, loss of revenue, damage to the brand, and losing the trust of customers.

For SMEs, it will be better to outsource the incident management process as they will have a dedicated team for the process, and the SMEs might not have the resources or the team to create a plan. Even if they do have a team, it is still better to outsource as, according to (Shinde & Kulkarni, 2021) the industry is increasingly adopting multiple frameworks for incident management rather than relying on a single one. This is due to making sure to meet the client's requirements, which might be diverse at times, and to create a comprehensive strategy that will address all the aspects of the organization's security infrastructure. So the team the SMEs have might not be knowledgeable in all the frameworks. Lastly, once the plan has been created, the

necessary security training sessions should be facilitated to educate all employees in the organization (Sicard, 2019).

Security Training and Education

Security training and education are vital components of an SME's information security management strategy. The primary goal is to reduce human error, which is one of the leading causes of security breaches. According to Verizon's 2023 Data Breach Investigations Report, 74% of all breaches include human error, such as being a victim of social engineering, misusing their privileges, or even having credentials stolen (K, 2023).

Providing Security training and education within SMEs and large organizations has its differences. However, having a security policy, whether in large organizations or SMEs, has a positive effect on the number of security incidents that take place, and the firm size does not play a significant role (Kweon et al., 2019). It will be significantly difficult for SMEs to hire and retain professional employees who specialize in Information Security Training and Education (ISTE), as it might be difficult to provide sufficient pay and benefits to them (Kweon et al., 2019). Compared to large organizations that will have the funds and facilities needed to hire experts in ISTE. Not providing ISTE in SMEs can result in a great loss due to the damages that are caused by cyber-attacks such as monetary and physical damages (Kweon et al., 2019).

SMEs should implement ISTE as their main goal should be to train and educate their employees to create awareness of threats and reduce human error as that has been the major cause of security incidents to take place, so that their firms are protected from external threats and to reduce the occurrence of potential security incidents (Kweon et al., 2019). This will help the SMEs run their business securely and keep in operation without having the fear of business closing down due to threats as they will be educated and prepared to minimize the occurrence of threats.

SMEs need ISM to secure their chances of not being victimized by cyber-attacks, and to do that, they need to use methods and factors to enhance the Information Security Awareness (ISA) of employees by implementing a security culture, implementing security policies, and providing security education and training (Khando et al., 2021). SMEs should take into consideration what methods they use. As the author (Khando et al., 2021) states, "Understanding the methods and factors used to enhance employees' ISA is crucial for organizations to develop effective ISA content."

Due to this reason, it will be better for SMEs to outsource the training by professionals as it will give them a better understanding when being educated by experts rather than having to hire their own team, which can be costly. Large organizations, on the other hand, have the resources to have their own team and provide the necessary training and education on a regular basis. SMEs can also provide online education opportunities to employees and insist on doing certifications regarding security training and education to enhance the company's security awareness.

Conclusion

In conclusion, information security management for SMEs is an essential strategy that SMEs must adopt to survive in today's digital world. Despite their size, SMEs face a lot of cybersecurity risks, with many underestimating their vulnerability due to them thinking that hackers will only attack large organizations. In reality, 31% of cyberattacks are directed towards SMEs, because of their lack of security measures. This irresponsibility can lead to financial losses, reputational damage, and potential legal consequences.

Given that SMEs are often less financially stable compared to large organizations, the impact of a cyberattack can be far more severe. Unlike large corporations that can quickly recover from an attack, many SMEs may be forced out of business after a significant security breach. Studies show that four out of five businesses that suffer a technology disruption fail within 18 months.

One of the critical components of ISM is incident response management, which equips SMEs with the tools and processes needed to detect cyber threats and respond quickly. When a business has an effective incident response plan in place, it can contain and minimize the damage from a security breach, ensuring that the attack does not go out of control. Another crucial element is disaster recovery planning. For SMEs, developing a disaster recovery plan that covers both natural and man-made disasters, including cyberattacks, is vital. This enables the company to recover quickly from an attack and restore normal operations without incurring significant downtime, which can be a disaster for a smaller business.

Furthermore, security training and education play a pivotal role in strengthening the security of SMEs. Human error is one of the leading causes of security breaches, with 74% of all breaches involving some form of human failure. By implementing regular security training programs, SMEs can reduce the risk of employees falling victim to cyberattacks. Security awareness is particularly important in SMEs, where resources are limited, and the margin for error is slim.

For many SMEs, outsourcing incident response, disaster recovery, and security training to third-party experts may be a cost-effective and efficient solution. Professional cybersecurity firms can provide specialized expertise that SMEs often cannot afford to maintain in-house, ensuring that their information security is handled with the same diligence and thoroughness as in larger corporations.

Ultimately, by embracing information security management, SMEs can protect themselves from the growing threat of cyberattacks within the digital world and ensure their long-term success.

Reference:

- K, K. K. (2023). 2023 Data Breach Investigations Report. In *Data Breach Investigations Report*.
- Khan, M. I., Tanwar, S., & Rana, A. (2020). The Need for Information Security Management for SMEs. <https://doi.org/10.1109/smart50582.2020.9337108>
- Khando, K., Gao, S., Islam, M. S., & Salman, A. (2021). Enhancing employees information security awareness in private and public organisations: A systematic literature review. *Computers & Security*, 106. <https://doi.org/10.1016/j.cose.2021.102267>
- Kweon, E., Lee, H., Chai, S., & Yoo, K. (2019). The Utility of Information Security Training and Education on Cybersecurity Incidents: An empirical evidence. *Information Systems Frontiers*, 23. <https://doi.org/10.1007/s10796-019-09977-z>
- Shinde, N., & Kulkarni, P. (2021). Cyber incident response and planning: a flexible approach. *Computer Fraud & Security*, 2021. [https://doi.org/10.1016/s1361-3723\(21\)00009-9](https://doi.org/10.1016/s1361-3723(21)00009-9)
- Sicard, K. (2019). The Need for Disaster Recovery and Incident Response: Understanding Disaster Recovery for Natural Disasters Versus Cyber-Attacks. *Kennesaw Journal of Undergraduate Research*, 6. <https://doi.org/10.62915/2474-4921.1167>